

Manual 45 — Capstone de Capacitación de Cumplimiento Empresarial

Idioma controlado: español latinoamericano (es-419). Este capstone es material de capacitación elaborado por el proyecto e integra los Manuales Prácticos de GRC publicados. No reproduce texto protegido de normas ni sustituye asesoría legal, regulatoria, de auditoría o certificación.

Chapter 01 — Propósito del Capstone

Definir escenario, objetivos, derechos de decisión, evidencia y criterios de finalización. El participante debe demostrar integración de gobierno, riesgo, cumplimiento, ciberseguridad, privacidad, resiliencia, terceros, nube, OT, IA y aseguramiento.

Chapter 02 — Escenario Empresarial

Establecer una empresa multinacional con operaciones reguladas, nube, procesos con IA, proveedores críticos, datos personales, obligaciones financieras y tecnología operacional. Registrar supuestos y separar hechos de decisiones del escenario.

Chapter 03 — Carta de Gobierno

Crear una carta con supervisión de junta, responsabilidad ejecutiva, propietarios de políticas, aceptación de riesgo, escalamiento, excepciones y aseguramiento independiente.

Chapter 04 — Aplicabilidad Regulatoria

Construir un registro que vincule jurisdicciones, actividades, datos, sectores, contratos y sistemas regulados con obligaciones aplicables, fuente autoritativa, responsable y fecha de revisión.

Chapter 05 — Arquitectura de Controles

Separar objetivo, actividad, implementación, evidencia, propietario, frecuencia, método de prueba y obligaciones mapeadas. Evitar duplicación cuando un control efectivo satisface múltiples requisitos.

Chapter 06 — Taxonomía de Riesgo

Crear una taxonomía común para riesgos cibernéticos, privacidad, IA, resiliencia, reporte financiero, proveedores, operación, legal y estrategia, con criterios consistentes de impacto y exposición residual.

Chapter 07 — Inventario de Activos y Servicios

Mantener inventarios autoritativos de servicios, aplicaciones, infraestructura, datos, IA, OT, proveedores, identidades y dependencias críticas con propietario y estado de ciclo de vida.

Chapter 08 — Gobierno de Datos

Definir clasificación, propósito, retención, minimización, residencia, acceso, intercambio, eliminación y linaje, vinculando controles con sistemas, proveedores, IA y derechos de privacidad.

Chapter 09 — Identidad y Acceso

Definir ciclo de identidad, privilegios, autenticación, federación, segregación de funciones, recertificación, identidades de servicio y acceso de emergencia.

Chapter 10 — Configuración Segura

Establecer baselines aprobados para endpoints, servidores, nube, red, bases de datos, SaaS, OT y herramientas de seguridad con gestión de desviaciones y evidencia.

Chapter 11 — Gestión de Vulnerabilidades

Definir descubrimiento, validación, priorización, remediación, excepciones, controles compensatorios y verificación, considerando explotabilidad, exposición, criticidad y amenaza.

Chapter 12 — Desarrollo Seguro

Integrar requisitos, modelado de amenazas, revisión de código, dependencias, pruebas, aprobación de liberación, procedencia, secretos y respuesta a vulnerabilidades.

Chapter 13 — Gobierno de IA

Inventariar casos y modelos, clasificar riesgo y documentar propósito, supervisión humana, procedencia de datos, evaluación, seguridad, privacidad, transparencia, monitoreo, cambios e incidentes.

Chapter 14 — Seguridad de IA

Abordar inyección de prompts, uso inseguro de herramientas, fuga de datos, cadena de suministro, integridad RAG, permisos de agentes, registros, guardrails, red teaming y comportamiento seguro ante fallas.

Chapter 15 — Ingeniería de Privacidad

Traducir obligaciones en controles para avisos, derechos, minimización, finalidad, retención, seguridad, encargados, transferencias internacionales y decisiones automatizadas.

Chapter 16 — Riesgo de Terceros

Definir ingreso, riesgo inherente, due diligence, contratos, requisitos de seguridad/privacidad, monitoreo, hallazgos, concentración, cuartos terceros y terminación.

Chapter 17 — Gobierno de Nube

Definir landing zones, cuentas, IAM, red, cifrado, logging, llaves, postura, backup, resiliencia, propietarios y responsabilidad compartida.

Chapter 18 — Seguridad OT e ICS

Separar seguridad operacional y restricciones de IT común. Incluir segmentación, acceso remoto, visibilidad, cambios, monitoreo, proveedores, respaldo, recuperación e incidentes.

Chapter 19 — Detección y Registros

Definir logging de seguridad, privacidad, IA, aplicaciones, nube, identidad y OT, con retención, integridad, sincronización, detecciones y preservación de evidencia.

Chapter 20 — Respuesta a Incidentes

Crear clasificación, mando, investigación, contención, erradicación, recuperación, evaluación legal/privacidad, notificación, comunicaciones, evidencia y lecciones aprendidas.

Chapter 21 — Continuidad del Negocio

Mapear servicios críticos con objetivos de recuperación, dependencias, personas, instalaciones, proveedores, tecnología, datos y procesos alternos, con pruebas realistas.

Chapter 22 — Recuperación ante Desastres

Definir niveles de recuperación, integridad de backups, restauración, ambientes alternos, dependencias, validación y ciber-recuperación.

Chapter 23 — Controles Financieros y de TI

Integrar ITGC, accesos, cambios, operaciones, interfaces, reportes, controles automatizados, evidencia, deficiencias y remediación con GRC empresarial.

Chapter 24 — Operaciones de Cumplimiento

Diseñar ingreso de obligaciones, mapeo, calendario de pruebas, evidencia, issues, cambios regulatorios, políticas, atestaciones, excepciones y reportes.

Chapter 25 — Aseguramiento y Auditoría

Definir monitoreo de primera línea, desafío de segunda línea, independencia de auditoría, muestreo, pruebas, papeles de trabajo, evidencia, calificación de hallazgos y validación de cierre.

Chapter 26 — Métricas y KRI

Seleccionar métricas orientadas a resultados para exposición, desempeño de controles, excepciones, remediación, incidentes, terceros, IA, privacidad, resiliencia y auditoría.

Chapter 27 — Reporte Ejecutivo

Reportar a junta y ejecutivos exposición, efectividad, cambios significativos, riesgo aceptado, remediación vencida, riesgos emergentes, incidentes y decisiones requeridas.

Chapter 28 — Gestión de Evidencia

Definir fuente, propietario, frecuencia, referencia inmutable, método de colección, retención, acceso, calidad y vínculo con controles y pruebas.

Chapter 29 — Ejercicio Integrado

Ejecutar un escenario que combine compromiso de proveedor, exposición cloud, flujo con IA, impacto de privacidad, interrupción operacional y posible obligación de divulgación.

Chapter 30 — Respuesta de la Gerencia

Documentar decisiones ejecutivas, aceptación o remediación de riesgo, responsables, fechas, recursos, comunicación y validación posterior.

Chapter 31 — Evaluación del Capstone

Evaluar completitud, trazabilidad, diseño de controles, calidad de evidencia, razonamiento de riesgo, coordinación y distinción entre requisito e interpretación.

Chapter 32 — Publicación y Mejora Continua

Congelar el paquete final solo después de verificar publicación del predecesor, fuentes, paridad trilingüe, integridad de artefactos, QA documental/render, accesibilidad, seguridad del repositorio, procedencia y aprobación humana final.